

Nottingham Trent University

COMP40741 – Ethical Hacking and Penetration Testing

Coursework 2 – Report

Simone Baidya (N1328138)
31/03/2025

Table of Contents

1. Introduction.....	2
1.1 Overview:.....	2
2. Lab Setup	3
2.1 Virtual Environment Setup:	3
2.2 Network Setup:	7
3. Penetration Testing Methodology	8
3.1 Information Gathering	13
3.2 Target / Network Scanning.....	15
3.3 Vulnerability Identification and Assessment.....	24
3.4 Exploitation of an Identified Vulnerability	35
4. Findings, Risk Analysis and Recommendation	38
5. Conclusion	44
6. References.....	45

1. Introduction

1.1 Overview:

Acme Corporation, a mid-sized e-commerce and online retail company, operates a web application for online transactions, a database server for managing customer and order data, and a corporate intranet for internal operations. Given the increasing frequency and sophistication of cyber threats targeting e-commerce platforms including SQL injection attacks, credential theft, ransomware, and data breaches the company recognizes the need for a proactive security assessment.

To mitigate potential cybersecurity risks, Acme Corporation has engaged our cybersecurity consultancy to conduct a penetration test. The objective is to simulate real-world cyberattacks to identify and validate vulnerabilities in the company's IT infrastructure, assess the impact of potential exploits, and recommend actionable security improvements.

This penetration test will follow industry-recognized best practices and frameworks, including:

- OWASP Testing Guide (for web application security)
- NIST SP 800-115 (for penetration testing methodologies)
- MITRE ATT&CK Framework (for adversary tactics and techniques)
- Common Vulnerability Scoring System (CVSS) for risk evaluation

The findings from this assessment will provide Acme Corporation with detailed insights into security gaps, ensuring that appropriate mitigation strategies are implemented to protect customer data, maintain regulatory compliance, and strengthen the organization's overall cybersecurity resilience.

Additionally, this penetration test will provide Acme Corporation with a thorough evaluation of its security posture, helping the company proactively mitigate cybersecurity risks before they can be exploited by real-world attackers. By simulating advanced cyber threats and applying ethical hacking methodologies, the assessment aims to:

- Strengthen network and web application security.
- Improve incident detection and response capabilities.
- Ensure compliance with regulatory and industry security standards.
- Reduce financial and reputational risks associated with cyberattacks.

The final report will serve as a strategic roadmap for Acme Corporation to enhance its overall cybersecurity resilience and protect its critical digital assets.

2. Lab Setup

In this report, the penetration test is carried out in a controlled virtual lab environment that is designed to emulate and in relation to Acme Corporation's infrastructure. The lab setup consists of the following configurations:

2.1 Virtual Environment Setup:

Virtual Machine (VM) – “UTM”:

Brief Overview:

UTM that is used mainly for macOS is a virtualization application that enables users to run different operating systems, such as Linux, Metasploitable, Windows, and macOS, on Apple devices. Utilizing QEMU and Apple's Hypervisor framework, it offers an intuitive interface for both virtualization and emulation. With support for both x86 and ARM architectures, UTM is a versatile solution for running legacy or alternative OS environments on Mac without relying on Boot Camp or Parallels (UTM Documentation, n.d).

Using UTM Virtual Machine for Acme Corporation's Penetration Testing:

A UTM Virtual Machine for macOS can play a crucial role in Acme Corporation's penetration testing process in several ways:

1. Ethical Hacking Lab Setup:

- A UTM VM enables security professionals to create a virtual penetration testing environment on macOS. By installing Kali Linux and Metasploitable, in this case, testers can conduct security assessments of Acme's web applications and network in a controlled setting.
- This approach ensures that attack simulations do not interfere with Acme's live systems.

2. Network Security Evaluation:

- A UTM-based firewall (such as pfSense or Sophos UTM) can be deployed in a virtualized environment to simulate Acme's network defences.
- Testers can assess how well Acme's security policies protect against intrusions, malicious traffic, and potential exploits.

3. Threat Simulation and Defense Testing:

- Since Acme is concerned about SQL injection, ransomware, and credential theft, a UTM VM can help analyse how effectively their security systems detect and block these threats.
- Features like Intrusion Detection and Prevention Systems (IDS/IPS) within a UTM VM can provide valuable insights into network vulnerabilities and attack mitigation strategies.

4. Practical Training and Technical Reporting:

- As the scenario is designed for hands-on learning, UTM for macOS allows students to set up a portable penetration testing lab, enabling them to safely perform security evaluations.
- The findings from these tests can be documented in detailed penetration testing reports, offering Acme actionable recommendations to strengthen its security.

Conclusion:

By integrating UTM Virtual Machines into the penetration testing process, security professionals can simulate real-world attacks, assess Acme's network resilience, and provide critical security insights. This approach offers a cost-effective, controlled, and portable solution for conducting ethical hacking assessments on macOS.

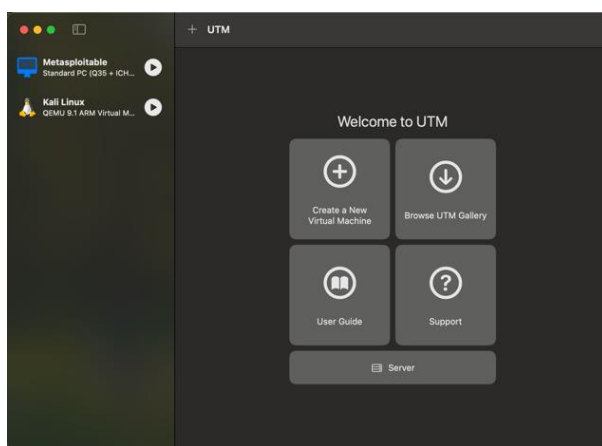


Figure 1. UTM Virtual Machine (VM) Framework.

Kali Linux:

Generally, Kali Linux is a known and described as a Debian-based operating system that is designed specifically for penetration testing, ethical hacking, and cybersecurity research. Therefore, it is developed and maintained by "Offensive Security" and it comes with a comprehensive set of pre-installed tools for tasks such as vulnerability assessment, digital forensics, reverse engineering, and wireless network testing (TheKnowledgeAcademy, n.d.). In addition to the statement, Kali Linux is considered, known and acts as an "attacker's machine", in this case.

Main Key Features of Kali Linux:

- **Extensive Security Toolset:** This stage includes powerful tools such as Metasploit, Nmap, Wireshark, John the Ripper, Aircrack-ng, and Burp Suite.
- **Highly Customizable:** In this stage, this type of feature allows users to create personalized Kali builds to suit specific needs.
- **Live Boot Capability:** This is another type of feature where it can be run directly from a USB drive without requiring installation.
- **Frequent Updates:** This is one of the types of features which ensures that regular maintenance is processed to ensure tools stay current and are updated.

- **Cross-Platform Compatibility:** This type of feature is only known to be available for ARM devices, virtual machines, cloud environments, and Windows Subsystem for Linux (WSL).

In overall summary, Kali Linux is one of the operating system that is widely and mostly used by cybersecurity professionals and ethical hackers as it is known to be a powerful tool for security testing, in specific. However, this operating system must be used responsibly and accordingly and only in compliance with legal and ethical guidelines, and it needs to make sure that these regulations and guidelines are securely in place and applied at the right time.

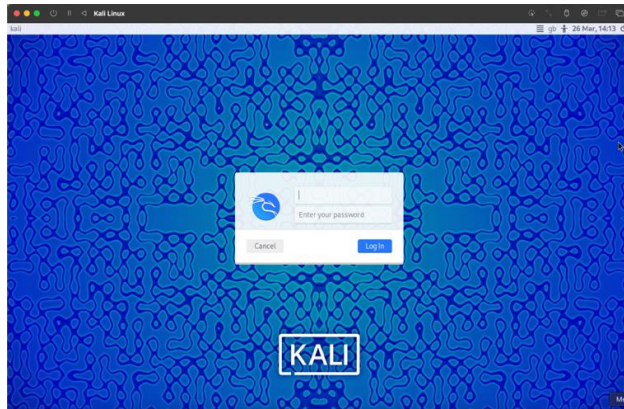


Figure 2. Set up and the Login Portal of Kali Linux.

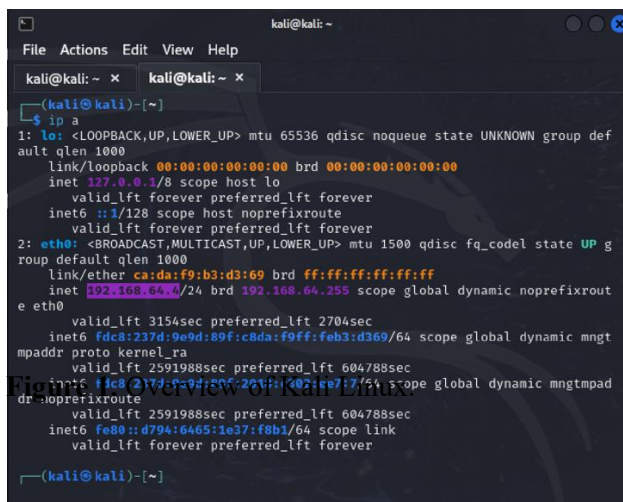


Figure 3. Configuration of IP address (192.168.64.4) using and entering “ip a” command.

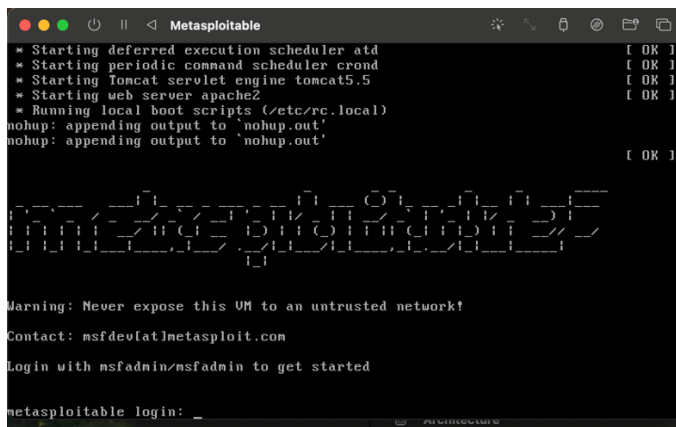
Metasploitable:

Metasploitable is an intentionally vulnerable virtual machine created for penetration testing practice and security evaluation. Developed by Rapid7, it provides a controlled environment where ethical hackers can refine their skills and test exploits using tools such as the Metasploit Framework (Metasploit Documentation, n.d.). Additionally, Metasploitable is also considered, known and acts as a “target”, in this case.

In terms of key features, Metasploitable has the only disadvantage and that is that it comes pre-configured with numerous security flaws, including weak settings, outdated software, and misconfigured applications. It is designed for practicing exploit execution, privilege escalation, and post-exploitation strategies. Furthermore, this type of vulnerable virtual machine serves as an excellent resource for cybersecurity training, Capture the Flag (CTF) competitions, and lab simulations and it therefore features commonly exploited services such as FTP, SSH, MySQL, Apache, and Tomcat to name a few.

Additionally, Metasploitable is widely utilized in cybersecurity education and ethical hacking in order to help professionals analysing real-world attack vectors in a safe and controlled setting and environment.

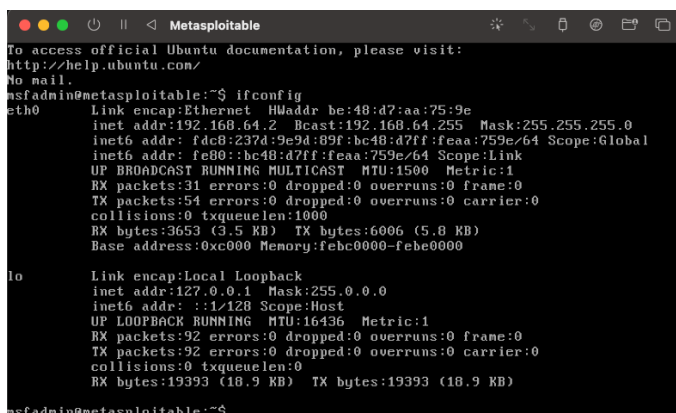
An overview of the machine can be seen in the figure below:



```
Metasploitable
* Starting deferred execution scheduler atd [ OK ]
* Starting periodic command scheduler crond [ OK ]
* Starting Tomcat servlet engine tomcat5.5 [ OK ]
* Starting web server apache2 [ OK ]
* Running local boot scripts (/etc/rc.local)
nohup: appending output to 'nohup.out'
nohup: appending output to 'nohup.out' [ OK ]

Warning: Never expose this VM to an untrusted network!
Contact: msfdev@metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: _
```

Figure 4. Metasploitable Framework using “UTM” VM.



```
Metasploitable
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr bc:48:d7:aa:75:9e
          inet addr:192.168.64.2  Bcast:192.168.64.255  Mask:255.255.255.0
          inet6 addr: fe80::bc48:d7ff:feaa:759e/64 Scope:Global
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:31 errors:0 dropped:0 overruns:0 frame:0
          TX packets:54 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3653 (3.5 KB)  TX bytes:6006 (5.8 KB)
          Base address:0xc000 Memory:febc0000-febe0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:92 errors:0 dropped:0 overruns:0 frame:0
          TX packets:92 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19393 (18.9 KB)  TX bytes:19393 (18.9 KB)

msfadmin@metasploitable:~$
```

Figure 5. Configuration of IP address (192.168.64.2) by entering the username and password “msfadmin” and then followed by “ifconfig” command to view its IP address, as shown in the figure above.

2.2 Network Setup:

Network Address Translation (NAT):

NAT (Network Address Translation) is a technique used in networking to modify the IP addresses in packet headers as they pass through a router or firewall. It allows multiple devices on a private network to share a single public IP address when accessing external networks like the internet. NAT changes the private IP addresses of devices within a local network into a public IP address for communication with external networks. This is especially useful when there is a shortage of public IP addresses, enabling multiple devices to connect to the internet using just one public IP address (Computer Networks, n.d).

In penetration testing, NAT (Network Address Translation) is a key concept, as it can affect how network traffic is routed and influence the way vulnerabilities are discovered and exploited. NAT allows multiple devices on a private network to share a single public IP address when communicating with external networks, such as the internet. While this technique is commonly used in most network environments, it can present challenges during penetration testing by masking internal systems and complicating access to private network resources. The screenshot below is the demonstration:

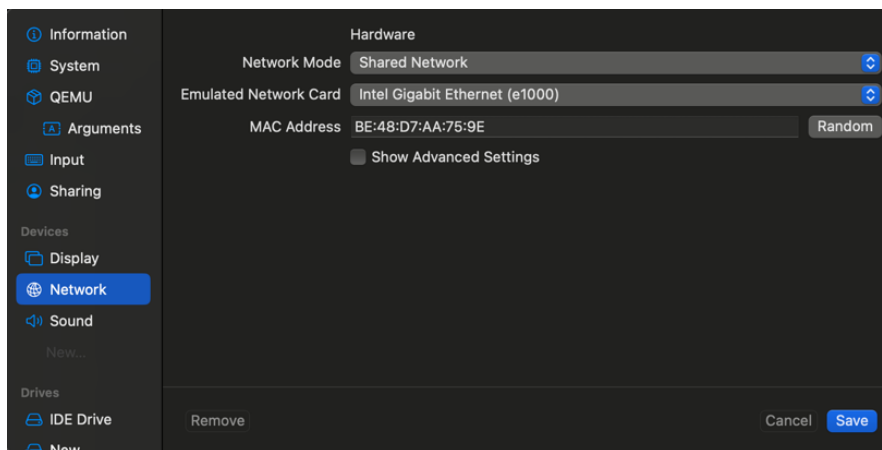


Figure 6. Set up of the NAT (in this case it is known as “Shared Network”).

3. Penetration Testing Methodology

McCarvill A., 2024, has stated that “*The term penetration testing (pentesting) refers to processes, tools, and services designed and implemented for the purpose of simulating attacks and data breaches, and finding security vulnerabilities*”. In other term, a Penetration Testing Methodology is a structured process used to evaluate the security of systems, networks, or applications by simulating real-world cyberattacks. It provides a systematic approach to identifying, exploiting, and documenting security vulnerabilities to enhance overall protection.

The methodology typically consists of the following key phases:

- 1. Planning & Reconnaissance** – Defining the scope, gathering intelligence, and understanding the target environment.
- 2. Scanning & Enumeration** – Identifying active hosts, open ports, services, and vulnerabilities through automated and manual techniques.
- 3. Exploitation** – Attempting to exploit discovered vulnerabilities to gain unauthorized access or escalate privileges.
- 4. Post-Exploitation & Lateral Movement** – Assessing the impact of successful exploitation, maintaining access, and moving across systems if applicable.
- 5. Reporting & Remediation** – Documenting findings, assessing risks, and providing recommendations to strengthen security.

Several well-known penetration testing methodologies include:

- **OWASP Testing Guide** – Focused on web application security.
- **NIST SP 800-115** – Guidelines for information security assessments.
- **PTES (Penetration Testing Execution Standard)** – A comprehensive framework covering all aspects of penetration testing.

Types of Penetration Tests:

Penetration tests can vary depending on the scope, target, and approach. Each type focuses on identifying specific vulnerabilities within systems, networks, or applications. Below are the most common types of penetration tests:

1. Black Box Testing

Best for: Simulating external cyberattacks.

In Black Box Testing, the tester has no prior knowledge of the system, simulating a real-world external attacker. The tester must discover vulnerabilities through methods like reconnaissance and scanning without inside information.

Key Features:

- No internal knowledge or access to system details.
- Focuses on external-facing systems like websites, APIs, and network services.
- Simulates an attack from an outsider's perspective.

2. White Box Testing

Best for: Thorough, internal system analysis.

In White Box Testing, the pen tester has full knowledge of the system, including its architecture and source code. This allows for a more in-depth review, often uncovering vulnerabilities that are harder to detect in other types of tests.

Key Features:

- Complete access to system architecture and source code.
- Allows for more extensive testing.
- Typically used when internal security configurations are known or need to be deeply assessed.

3. Gray Box Testing

Best for: Simulating insider attacks with limited access.

Gray Box Testing combines aspects of both Black and White Box Testing. The tester has partial knowledge of the target system—such as user credentials or high-level architecture. This approach is used to simulate attacks from insiders or users with limited access.

Key Features:

- Partial knowledge of system internals.
- Tests both external and internal perspectives.

- Often used to mimic attacks by users with restricted access or compromised accounts.

4. External Penetration Testing

Best for: Evaluating perimeter security.

External Penetration Testing focuses on identifying vulnerabilities in systems that are accessible from outside the organization, such as web servers, email systems, and public-facing applications. It simulates an attack from an external threat actor attempting to breach perimeter defences.

Key Features:

- Focuses on publicly accessible systems and services.
- Tests perimeter defences like firewalls, routers, and VPNs.
- Targets online resources like websites and APIs.

5. Internal Penetration Testing

Best for: Assessing security within an organization's network.

Internal Penetration Testing simulates an attack from inside the organization, such as from a disgruntled employee or a compromised internal account. The tester is typically granted internal access (e.g., network access or valid credentials) to identify vulnerabilities within the network.

Key Features:

- Tests defences against insider threats or compromised accounts.
- Assesses internal network security, including segmentation and access controls.
- Helps evaluate the ability of internal defences to mitigate breaches.

6. Web Application Penetration Testing

Best for: Identifying vulnerabilities in web applications and APIs.

Web Application Penetration Testing specifically focuses on finding weaknesses in web applications, such as SQL injection, XSS, authentication flaws, and broken access control. This test simulates an attack targeting a web-based service or API.

Key Features:

- Focuses on web applications, APIs, and related services.
- Tests for vulnerabilities like SQL injection, XSS, and insecure authentication.
- Typically targets vulnerabilities unique to web environments.

7. Social Engineering Penetration Testing

Best for: Testing human vulnerabilities and awareness.

Social Engineering Penetration Testing simulates attacks that manipulate individuals into revealing sensitive information or granting unauthorized access. It tests the organization's ability to defend against tactics like phishing, pretexting, or baiting.

Key Features:

- Involves tactics like phishing, baiting, and impersonation.
- Tests the organization's defence against social manipulation.
- Can include email-based attacks or physical attempts to bypass security (e.g., tailgating).

8. Physical Penetration Testing

Best for: Assessing physical security measures.

Physical Penetration Testing evaluates the effectiveness of an organization's physical security, such as locks, access controls, and surveillance systems. The tester tries to gain unauthorized physical access to critical infrastructure or facilities.

Key Features:

- Tests physical security measures like locks, barriers, and surveillance.
- Attempts to gain unauthorized physical access to restricted areas.
- Identifies weaknesses in physical security systems that could be exploited.

9. Red Teaming

Best for: Comprehensive, full-scope security testing.

Red Teaming takes a more holistic approach, simulating real-world attacks from multiple vectors, including technical, physical, and human aspects. A Red Team uses all available methods—external, internal, social engineering, and physical penetration—to test an organization's security preparedness.

Key Features:

- Involves testing from all attack vectors (technical, physical, human).
- Focuses on how well an organization detects, responds, and recovers from attacks.
- A comprehensive test that mimics a realistic multi-faceted attack.

10. Wireless Network Penetration Testing

Best for: Testing the security of wireless networks.

Wireless Network Penetration Testing assesses vulnerabilities in wireless networks, such as Wi-Fi and Bluetooth. The tester evaluates encryption methods, signal strength, and configurations to identify weaknesses that could be exploited.

Key Features:

- Focuses on Wi-Fi networks, Bluetooth, and other wireless protocols.
- Tests encryption, rogue access points, and network configurations.
- Identifies potential eavesdropping or unauthorized access to wireless networks.

Summary Table of Penetration Testing Types

<u>Type of Test</u>	<u>Focus Area</u>
Black Box Testing	External attacker simulation with no internal knowledge
White Box Testing	Thorough internal system review with full knowledge of the system
Gray Box Testing	Testing from an insider perspective with partial knowledge
External Penetration Testing	Testing external-facing systems and perimeter defenses
Internal Penetration Testing	Testing internal network security and potential insider threats
Web Application Penetration Testing	Evaluating vulnerabilities in web apps, websites, and APIs
Social Engineering Penetration Testing	Testing human vulnerabilities through deception and manipulation
Physical Penetration Testing	Assessing physical security measures and access controls
Red Teaming	Comprehensive, multi-faceted attack simulation covering all vectors
Wireless Network Penetration Testing	Testing the security of wireless networks and devices

3.1 Information Gathering

Information Gathering in Penetration Testing

According to Teendifferent, 2022, “*Information Gathering means gathering different kinds of information about the target*”. In addition to this, Information gathering is a crucial first step in penetration testing, serving as the foundation for all subsequent phases. During this stage, the goal is to collect detailed information about the target system, network, or organization. The data gathered helps identify potential vulnerabilities and attack vectors, offering valuable insights that guide the next steps in the testing process.

Information gathering is categorized into two primary types: Passive Information Gathering and Active Information Gathering.

1. Passive Information Gathering

Passive information gathering entails collecting data without directly engaging with the target system. This method minimizes the risk of detection by avoiding the sending of probes or requests that could alert the target. Instead, it relies on publicly accessible information and open-source intelligence (OSINT).

Techniques in Passive Information Gathering:

- **WHOIS Lookup:** Collecting domain registration details such as the owner, associated IP addresses, and nameservers.
- **DNS Record Analysis:** Extracting DNS records, including A records, MX records, and TXT records, to uncover information about the domain’s infrastructure and associated servers.
- **Social Media Analysis:** Analysing publicly available content shared on social media platforms to gather insights about employees, the organization, or technologies used.
- **Public Website Scraping:** Scraping publicly accessible websites for clues about infrastructure, technologies, employee roles, or security measures.
- **Google Dorking:** Utilizing advanced search queries to find sensitive information exposed on a website, such as login portals or hidden files.

Benefits of Passive Gathering:

The main benefits are that they tend to be stealthy and difficult to detect by the target. Also, it provides valuable intelligence that can be used to plan further attacks without triggering alarms.

2. Active Information Gathering

Active information gathering involves direct interaction with the target, which increases the risk of detection. This phase involves sending requests or probing the target system to gather more specific data.

Techniques in Active Information Gathering:

- **Ping Sweeps:** Identifying active hosts on a network by sending ICMP echo requests to a range of IP addresses.
- **Port Scanning (e.g., Nmap):** Scanning the target to identify open ports and services, which can help map out the target's network services and potential entry points.
- **Banner Grabbing:** Extracting details such as software versions and operating systems from services (e.g., web servers or FTP servers) that reveal this information through their banners.
- **Network Enumeration:** Gathering information about the target's network infrastructure, including connected devices, operating systems, and potentially vulnerable services.
- **Email Harvesting:** Collecting email addresses and associated metadata, which may be used in phishing attacks or social engineering.

Benefits of Active Gathering:

The benefits of Active Gathering are that it provides more granular and detailed information about the target, and it is essential for identifying specific vulnerabilities, open ports, and live systems that can be exploited in later stages.

The Importance of Information Gathering in Penetration Testing:

- **Laying the Groundwork for Exploitation:** Information gathered during this phase provides the foundation for more targeted attacks in the later stages of the penetration test.
- **Identifying Vulnerabilities:** Understanding the target's infrastructure and technologies allows penetration testers to identify weaknesses that could be exploited.
- **Optimizing Resource Allocation:** Effective information gathering helps focus efforts on the most likely vulnerabilities, making the penetration testing process more efficient and impactful.

3.2 Target / Network Scanning

Target/Network Scanning refers to the process of discovering and mapping out a network, including its devices and services, to identify potential vulnerabilities or weaknesses that could be exploited in a penetration test (Kirvan, P., Nolle, T. and Intel A., 2024). This phase helps penetration testers understand the structure of the network, the devices it contains, and any possible entry points for attacks.

Key Elements of Network Scanning:

1. IP Range Scanning: Scanning a range of IP addresses to identify active devices on the network, helping to build a map of the networked devices.

2. Port Scanning: Identifying open ports on each device. Open ports can indicate running services that might be vulnerable. Tools like Nmap or masscan are commonly used for this.

3. Service Enumeration: After detecting open ports, penetration testers examine the services running on those ports (e.g., HTTP, FTP, SSH) to identify their versions and configurations. This step reveals if these services have known security weaknesses.

4. OS Fingerprinting: Determining the operating systems of the devices on the network. This helps penetration testers customize their attacks based on specific vulnerabilities of those operating systems.

5. Vulnerability Scanning: Running automated scans to find known vulnerabilities within the network's services and systems using tools like Nessus or OpenVAS.

Network scanning is a critical part of the reconnaissance phase in penetration testing, helping to outline the testing scope by revealing vulnerable systems and potential attack vectors.

Tools for Information Gathering (Reconnaissance):

Information gathering is a crucial part of penetration testing, where data is collected about a target to identify potential vulnerabilities. Below are some commonly used tools for this purpose:

1. Nmap (Network Mapper)

Purpose: Discovering networks and performing security audits.

Features:

- Scans for open ports, services, and potential vulnerabilities.
- Detects operating systems and versions.

2. WHOIS

Purpose: Retrieving domain registration details.

Features:

- Provides information about domain owners, registrars, and contact data.
- Useful for identifying who is behind a domain and gathering contact information.

3. Recon-ng

Purpose: Framework for web-based reconnaissance.

Features:

- Automates data collection from various public sources (social media, DNS records, WHOIS).
- Includes modules for gathering OSINT (Open-Source Intelligence).

4. theHarvester

Purpose: Collecting emails, domains, and subdomains.

Features:

- Extracts information from search engines, social media, and public sources.
- Helps gather intelligence before targeting networks or applications.

5. Shodan

Purpose: Search engine for internet-connected devices.

Features:

- Discovers devices exposed to the internet, such as webcams and IoT devices.
- Provides information on device vulnerabilities.

6. Netcat

Purpose: Utility for reading and writing to network connections.

Features:

- Used for banner grabbing, simple port scanning, and establishing network connections.
- Helps interact with services or scan ports.

7. DNSdumpster

Purpose: DNS and domain reconnaissance.

Features:

- Analyses DNS records to identify subdomains, IP addresses, and network infrastructure.
- Provides a comprehensive view of a target's network setup.

8. Dig

Purpose: DNS lookup tool.

Features:

- Queries DNS servers for information about domains (e.g., A records, MX records).
- Helps gather DNS-related data for reconnaissance.

9. SpiderFoot

Purpose: Automated OSINT gathering.

Features:

- Collects data from a variety of public sources (DNS, WHOIS, social media) to map a target's infrastructure.
- Provides detailed reports on vulnerabilities and exposed information.

10. Google Dorking

Purpose: Advanced Google search for hidden data.

Features:

- Uses specialized search queries to uncover exposed data or misconfigurations on websites (e.g., admin login pages, backups).
- Helps find sensitive information that may be publicly accessible.

11. Metasploit (Information Gathering Modules)

Purpose: Penetration testing framework.

Features:

- Includes modules for scanning and gathering information.
- Helps identify vulnerabilities in networks and services, mapping out attack vectors.

These tools are used during the reconnaissance phase to gather valuable information about a target system, network, or application. Each tool serves a specific purpose, from DNS record analysis to social media scraping.

Step 1 – Finding Live Machines (Kali Linux):

Ping Sweep/Scan Method:

Ping Sweep/Scan (-sP) is a method used to identify active hosts within a specified range of IP addresses. It works by sending ICMP Echo Request packets (ping requests) to multiple devices on the network. Each request sends a single packet, typically consisting of 56 bytes of data and an 8-byte header, totalling 64 bytes. Devices that are online respond with ICMP Echo Reply packets, allowing the scanner to determine which IP addresses are in use and which are inactive. In addition to identifying live hosts, Ping Sweep also measures the round-trip time (RTT), which is the time it takes for the request to travel to the target and back. This provides valuable information about network latency, performance, and the health of the network.

Command:

`nmap -sP <target>`

For example:

`nmap -sP 198.168.64.2`

```
(kali㉿kali)-[~]
$ nmap -sP 192.168.64.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-26 20:11 GMT
Nmap scan report for 192.168.64.2
Host is up (0.00077s latency).
MAC Address: BE:48:D7:AA:75:9E (Unknown)
Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
```

Figure 7. Configuration and use of Ping Sweep/Scan Command.

```
(kali㉿kali)-[~]
$ ping 192.168.64.2
PING 192.168.64.2 (192.168.64.2) 56(84) bytes of data.
64 bytes from 192.168.64.2: icmp_seq=1 ttl=64 time=5.21 ms
64 bytes from 192.168.64.2: icmp_seq=2 ttl=64 time=2.26 ms
64 bytes from 192.168.64.2: icmp_seq=3 ttl=64 time=2.08 ms
64 bytes from 192.168.64.2: icmp_seq=4 ttl=64 time=1.98 ms
64 bytes from 192.168.64.2: icmp_seq=5 ttl=64 time=1.14 ms
64 bytes from 192.168.64.2: icmp_seq=6 ttl=64 time=1.53 ms
64 bytes from 192.168.64.2: icmp_seq=7 ttl=64 time=1.18 ms
64 bytes from 192.168.64.2: icmp_seq=8 ttl=64 time=1.76 ms
64 bytes from 192.168.64.2: icmp_seq=9 ttl=64 time=2.06 ms
64 bytes from 192.168.64.2: icmp_seq=10 ttl=64 time=1.91 ms
64 bytes from 192.168.64.2: icmp_seq=11 ttl=64 time=1.86 ms
64 bytes from 192.168.64.2: icmp_seq=12 ttl=64 time=2.17 ms
64 bytes from 192.168.64.2: icmp_seq=13 ttl=64 time=1.88 ms
64 bytes from 192.168.64.2: icmp_seq=14 ttl=64 time=0.515 ms
64 bytes from 192.168.64.2: icmp_seq=15 ttl=64 time=0.679 ms
64 bytes from 192.168.64.2: icmp_seq=16 ttl=64 time=1.84 ms
64 bytes from 192.168.64.2: icmp_seq=17 ttl=64 time=2.00 ms
64 bytes from 192.168.64.2: icmp_seq=18 ttl=64 time=1.98 ms
64 bytes from 192.168.64.2: icmp_seq=19 ttl=64 time=2.10 ms
64 bytes from 192.168.64.2: icmp_seq=20 ttl=64 time=1.74 ms
64 bytes from 192.168.64.2: icmp_seq=21 ttl=64 time=1.87 ms
64 bytes from 192.168.64.2: icmp_seq=22 ttl=64 time=2.00 ms
```

Figure 8. Demonstration of all the live and active machines.

Nmap Capabilities in Penetration Testing:

Introduction/Overview:

Shivanandhan, M., 2020, stated that “*It is an open-source Linux command-line tool that is used to scan IP addresses and ports in a network and to detect installed applications*”. In other word, Nmap or Network Mapper is a highly versatile and widely used tool in ethical hacking and penetration testing. It enables security professionals to assess network security by identifying active hosts, detecting open ports, determining running services, and uncovering potential vulnerabilities. With its extensive range of scanning techniques and automation capabilities, Nmap is an essential tool for conducting comprehensive security assessments. Below are its key features:

1. Identifying Active Hosts:

Nmap facilitates the discovery of live devices within a network using various scanning techniques, even when ICMP traffic is restricted.

- **Common Commands:**
 - “nmap -sn 192.168.1.0/24” – Conducts a basic ping scan to detect active hosts.
 - “nmap -Pn target.com” – Bypasses the ping check and assumes all hosts are online.
 - “nmap -PR 192.168.1.1/24” – Uses ARP requests for accurate local network detection.
- **Use Case:** Helps focus penetration testing efforts on active systems only.

2. Scanning for Open Ports:

Nmap detects open, closed, or filtered ports on a target device, revealing accessible services.

- **Types of Scans:**
 - **TCP SYN Scan (-sS):** A stealthy method that avoids completing the handshake.
 - **TCP Connect Scan (-sT):** Establishes full connections, making it more noticeable.
 - **UDP Scan (-sU):** Identifies UDP services like DNS and SNMP.
 - **Xmas and FIN Scans (-sX, -sF):** Useful for bypassing firewalls.
- **Example Command:**
 - “nmap -sS -p 80,443 192.168.1.1” – SYN scan targeting ports 80 and 443.

3. Detecting Services and Versions:

Nmap identifies the services running on open ports and determines their versions.

- **Example Commands:**
 - “nmap -sV -p 22,80,443 target.com”
 - “nmap -A 192.168.1.1” – Conducts an aggressive scan, including OS detection.
- **Use Case:** Identifies outdated services that may contain vulnerabilities.

4. Operating System Fingerprinting:

Nmap analyses TCP/IP stack behaviour to infer the target system’s OS.

- **Example Command:**
 - “nmap -O 192.168.1.1” – Attempts OS identification.
- **Use Case:** Assists in selecting appropriate exploits based on the detected OS.

5. Automating Scans with Nmap Scripting Engine (NSE):

The NSE enables automated vulnerability scanning and service enumeration.

- **Common Scripts:**
 - `--script=vuln` – Executes scripts to detect known vulnerabilities.
 - `--script=http-enum` – Enumerates web services.
 - `--script=auth` – Tests authentication mechanisms.
- **Example Command:**
 - `nmap --script=http-vuln-cve2017-5638 -p 80 target.com`

6. Bypassing Firewalls and Intrusion Detection Systems:

Nmap offers various evasion techniques to avoid detection by security defences.

- **Techniques:**
 - **Decoy Scanning (-D):** Uses multiple fake IP addresses to obscure the attacker's identity.
 - **MAC Address Spoofing (--spoof-mac):** Alters the attacker's MAC address.
 - **Fragmented Packet Scanning (-f):** Splits packets to evade detection.
- **Example Command:**
 - `nmap -D RND:10 192.168.1.1` – Deploys 10 random decoy addresses.

7. Network Mapping and Visualization:

Nmap can analyse a network's structure and generate a graphical representation of its topology.

- **Example Command:**
 - `nmap -sn --traceroute 192.168.1.1/24`
 - **Zenmap:** A GUI tool that visually represents network topology.

8. Enhancing Performance and Speed:

Nmap includes performance tuning options to optimize scan speed and efficiency.

- **Optimization Options:**
 - `-T0 (Paranoid)` – Slow but stealthy.
 - `-T5 (Insane)` – Maximizes speed but increases detectability.
 - `--min-rate 1000` – Enforces a minimum packet transmission rate.
- **Example Command:**
 - `nmap -T4 -p 1-65535 192.168.1.1` – Fast full-port scan.

9. Generating Reports and Saving Output:

Nmap allows results to be saved in multiple formats for documentation and further analysis.

- **Output Options:**
 - `-oN output.txt` – Saves results in a human-readable text format.
 - `-oX output.xml` – Generates an XML file.
 - `-oG output.gnmap` – Produces a format suitable for further scripting.
- **Example Command:**
 - `nmap -sV -oN scan_results.txt target.com`

In conclusion, Nmap is an essential tool in penetration testing, offering comprehensive scanning, enumeration, vulnerability detection, and evasion capabilities. It enables security professionals to assess and secure network infrastructures effectively.

Step 2 – Discovering Open Ports (Kali Linux):

In computer networking, a port acts as a logical communication endpoint, helping systems manage and distinguish various types of data exchanges. For instance, Server Message Block (SMB) is a protocol used by Windows machines for network file and printer sharing. It typically operates on TCP ports 138 and 445, which are essential for establishing connections and facilitating communication between devices.

When these ports are left open, they can pose a significant security threat. Cybercriminals can exploit vulnerabilities within the SMB protocol to gain unauthorized access to files, execute malicious code, or distribute malware across the network. A prominent example of such an attack was the WannaCry ransomware, which utilized an SMB v1 vulnerability (EternalBlue) to spread rapidly and affect countless systems globally.

In response to these risks, Microsoft issued patches to fix vulnerabilities in SMB v1 and recommended users disable it in favour of more secure versions like SMB v2 or v3. However, many individuals continue to use pirated or counterfeit versions of Windows, which are not eligible for official security updates, leaving them vulnerable to exploits that could otherwise be mitigated with proper patches.

Nmap Configuration:

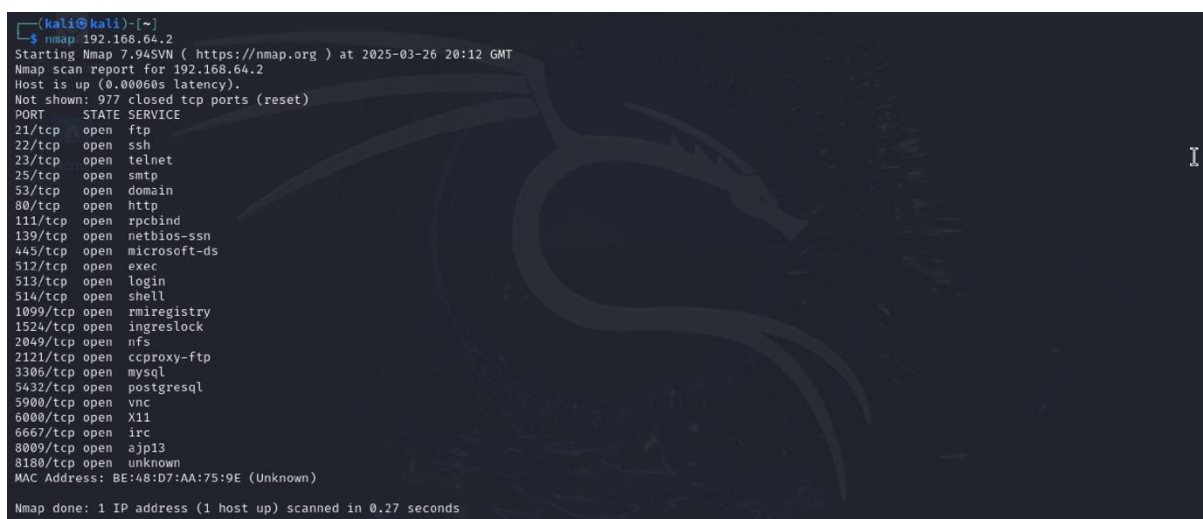
Command:

`nmap <target>`

For example:

`nmap 192.168.64.2`

Below is the screenshot and the demonstration of the command used:



```
(kali@kali)~$ nmap 192.168.64.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-26 20:12 GMT
Nmap scan report for 192.168.64.2
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: BE:48:D7:AA:75:9E (Unknown)

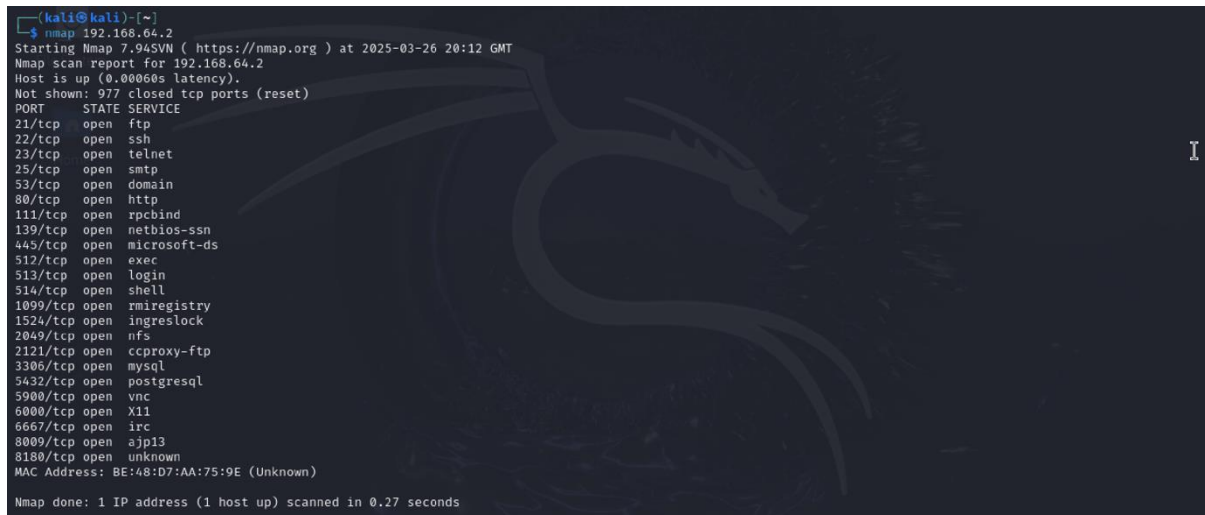
Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds
```

Figure 9. Discovering Open Ports using “Nmap” Command.

Step 3 – Running Services on the target machine:

One of Nmap's core functionalities is known for its ability to detect and identify active services running on a target system. It provides detailed information about open ports, their states (open, closed, or filtered), and the specific services associated with them. Additionally, Nmap can attempt service version detection, helping to determine the exact software running on a given port. This information is crucial for network administrators and security professionals to assess system configurations, identify potential vulnerabilities, and ensure proper access control.

Below is the demonstration of the task:



```
(kali@kali)~$ nmap 192.168.64.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-26 20:12 GMT
Nmap scan report for 192.168.64.2
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: BE:48:D7:AA:75:9E (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.27 seconds
```

Figure 10. Demonstration of Running Services.

Step 4 – Checking the OS version of the target machine:

Generally, an operating system and its version refer to a specific release of an OS, such as Microsoft Windows, Unix, or Linux. Each version may introduce new features, security enhancements, performance improvements, and compatibility changes tailored to different computing environments. These variations can impact system stability, application support, and vulnerability exposure.

In the screenshot shown below, the displayed Linux versions range from 2.6.9 to 2.6.33, which belong to the Linux 2.6 kernel series. This series introduced significant advancements in process scheduling, memory management, and security mechanisms, making it a crucial phase in Linux development.

```

(kali@kali)-[~]
└─$ nmap -O 192.168.64.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-26 20:13 GMT
Nmap scan report for 192.168.64.2
Host is up (0.0015s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  http
MAC Address: BE:48:D7:AA:75:9E (Unknown)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 1.57 seconds

```

Figure 11. Demonstration of the machine’s OS version.

Step 5 – Target Scanning Demonstration:

In this stage, Target scanning enables the user to analyse the operating system running on Metasploitable, including identifying open ports and their associated services. This process helps in determining the OS version, which is crucial for assessing potential security weaknesses. By researching known vulnerabilities associated with the detected OS version, we can evaluate possible attack vectors. This information can then be leveraged to simulate exploitation attempts, demonstrating how an attacker might compromise the system. Understanding these vulnerabilities allows security professionals to implement effective countermeasures and strengthen system defences. The screenshot shown below shows the demonstration.

```

(kali@kali)-[~]
└─$ nmap -sV 192.168.64.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-26 20:15 GMT
Nmap scan report for 192.168.64.2
Host is up (0.00060s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath gmrregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: BE:48:D7:AA:75:9E (Unknown)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.42 seconds

```

Figure 12. Demonstration of the Target Scanning (in this case the output of the Nmap scan that was performed for the following IP Address “192.168.64.2”).

3.3 Vulnerability Identification and Assessment

In penetration testing, vulnerability assessment is defined as the process of identifying, evaluating, and prioritizing security weaknesses in a network, system, or application. It involves scanning for known vulnerabilities and assessing their potential impact on security. Unlike penetration testing, which actively exploits these vulnerabilities, vulnerability assessment focuses on finding and documenting them without exploiting them.

Furthermore, Vulnerability assessment is a critical process in cybersecurity that involves systematically scanning and identifying potential security weaknesses within a target system or network. This is done using specialized tools designed to detect and evaluate misconfigurations, outdated software, and known vulnerabilities that could be exploited by attackers to compromise the system.

The process typically starts with scanning the target environment, which could be a single system, a network, or even a range of IP addresses. By performing these scans, the tools identify open ports, running services, and software versions, which are key indicators of potential vulnerabilities (Black duck, n.d.).

The key aspects to consider and look for in a vulnerability assessment are in the following:

1. Misconfigurations: Vulnerability assessment tools can detect misconfigurations in a system, such as improperly configured firewalls, weak access control policies, or incorrect system permissions. These misconfigurations can create unintended entry points for attackers, allowing unauthorized access or control over sensitive data.

2. Outdated Software: Many attacks exploit known vulnerabilities in outdated software or unsupported versions of programs. Vulnerability scanners can check for outdated software versions and compare them to public vulnerability databases (such as CVE or NVD) to identify any unpatched security flaws. For instance, a tool might discover an outdated version of Apache or Microsoft IIS, both of which could have well-known vulnerabilities that an attacker could exploit.

3. Potential Vulnerabilities: Scanning tools are capable of detecting potential vulnerabilities, including but not limited to:

- **Buffer overflows:** These occur when a program writes more data to a block of memory, which could overwrite adjacent memory and cause code execution.

- **Cross-Site Scripting (XSS):** This occurs when an attacker injects malicious scripts into websites, potentially leading to data theft or session hijacking.

- **SQL Injection:** A vulnerability in web applications where attackers can inject malicious SQL queries to manipulate databases.

- **Weak Passwords:** Some vulnerability scanners can test for weak or default passwords, which can be easily guessed or cracked by attackers.

4. Automated Vulnerability Databases: These tools often rely on extensive databases of known vulnerabilities, such as CVE (Common Vulnerabilities and Exposures), NVD (National Vulnerability Database), and other third-party exploit databases. By matching the findings with these databases, the tools can identify whether any of the detected issues have been publicly reported and can then assign risk levels based on their exploitability.

5. Comprehensive Reporting: Once the scan is complete, these tools generate detailed reports that include a list of discovered vulnerabilities, their severity, possible exploit scenarios, and recommendations for remediation. This allows security teams to prioritize issues based on risk, such as fixing critical vulnerabilities before low-priority ones.

Popular Vulnerability Assessment Tools:

- **Nmap:** Primarily known as a network discovery tool, Nmap also has powerful capabilities for service version detection and vulnerability scanning. With its scripting engine (NSE), it can check for specific vulnerabilities, such as those related to Heartbleed or SMB vulnerabilities.

- **Nessus:** A widely used vulnerability scanner that can detect a broad range of vulnerabilities, including configuration flaws, missing patches, and weaknesses in network protocols. It provides detailed reports and actionable remediation advice (Awati R., 2025).

- **OpenVAS:** An open-source vulnerability scanning tool that is highly customizable. It detects a wide array of vulnerabilities and is often used for large-scale scans of complex networks and infrastructures (GeeksforGeeks, 2024).

- **Nikto:** A web server scanner that focuses on identifying vulnerabilities specific to web applications, such as outdated software, insecure configurations, and potential injection flaws. It performs checks for more than 6,700 known security issues in web servers (ScienceDirect, n.d.).

By employing these tools, organizations can identify weaknesses in their systems before malicious actors can exploit them, thereby preventing data breaches, system compromises, and other security incidents. Regular vulnerability assessments should be part of any organization's cybersecurity strategy to maintain a strong defence against evolving threats.

The Role in Penetration Testing:

In penetration testing, vulnerability assessment plays a key role during the reconnaissance and pre-exploitation stages. Here's how it contributes:

1. Identifying Vulnerabilities: A vulnerability assessment helps uncover security issues such as outdated software, misconfigurations, weak passwords, or unpatched systems, which could be targeted during the penetration test.

2. Risk Prioritization: It evaluates the severity and likelihood of exploiting each vulnerability. This helps testers focus on the most critical issues that could cause significant damage if attacked.

3. Shaping the Attack Strategy: The findings from the vulnerability assessment give penetration testers a roadmap for crafting attack scenarios based on the vulnerabilities identified.

4. Increasing Testing Efficiency: By identifying high-risk vulnerabilities early on, a vulnerability assessment helps testers focus their efforts on the areas that need the most attention, making the penetration test more efficient.

5. Post-Test Remediation: After the penetration test, the vulnerabilities discovered during the assessment guide remediation efforts, helping the organization strengthen its security defenses.

In conclusion, vulnerability assessment provides essential information for a targeted and effective penetration test, allowing testers to identify critical weaknesses and design their attack strategy accordingly.

Nmap Vulnerability Scan Using NSE Scripts:

Goodman C., 2025, has stated that “*Common Vulnerabilities and Exposures (CVE)* is a publicly accessible database that identifies and catalogs known security vulnerabilities in software and hardware”. To clarify, CVE (Common Vulnerabilities and Exposures) is a system used to catalog and classify software vulnerabilities. It provides a unique identifier for each known security flaw, making it easier to track and manage vulnerabilities across different software platforms and versions. In Nmap, NSE (Nmap Scripting Engine) scripts are designed to detect vulnerabilities in target systems by referencing CVE identifiers and other known vulnerability databases. These scripts can be used to automate vulnerability scanning, helping security professionals identify risks and weaknesses in their systems.

There are several Nmap NSE scripts used for vulnerability scanning, and three of the most popular ones are:

1. Nmap vulscan

Nmap vulscan is an NSE script that utilizes local CVE databases hosted on the client performing the scan.

2. Nmap-vulners

Nmap-vulners is another popular NSE script that focuses on detecting vulnerabilities by matching service versions with publicly available CVE data. It pulls information from several vulnerability databases, including those maintained by CVE, NVD (National Vulnerability Database), and Exploit-DB. Nmap-vulners is widely regarded for its effectiveness in identifying vulnerabilities associated with software and services, based on their version numbers.

Unlike **Nmap vulscan**, which requires external databases to be manually updated, **Nmap-vulners** can dynamically pull updated CVE information from multiple sources. This makes it easier to detect newly discovered vulnerabilities during a scan.

3. Nmap vuln

The **Nmap vuln** category includes a collection of vulnerability detection scripts, each designed to detect specific vulnerabilities based on predefined categories. These scripts are useful for performing targeted vulnerability assessments based on the type of vulnerability you are trying to detect.

Advantages of Using Nmap NSE Scripts for Vulnerability Scanning:

- **Comprehensive Coverage:** Nmap’s NSE scripts offer a broad range of vulnerability checks, from software misconfigurations to network service vulnerabilities.
- **Customizable:** Users can create or modify NSE scripts to suit specific scanning needs or target unique systems.
- **Efficient:** Nmap’s automation of vulnerability scanning reduces the need for manual checks and ensures that security teams can quickly identify and address weaknesses.
- **Regular Updates:** Many Nmap NSE scripts are maintained by a vibrant community, ensuring they stay up-to-date with the latest security findings.

Limitations:

- **False Positives/Negatives:** No vulnerability scanner is perfect, and Nmap is no exception. Results should be validated manually to ensure their accuracy.
- **Performance Impact:** Running intrusive scripts or a large number of vulnerability checks can have a performance impact on the target system, so it's important to conduct scans responsibly.

By using Nmap NSE scripts, organizations can automate vulnerability detection, save time on manual assessments, and better manage security risks across their networks and systems. Regular vulnerability scanning helps identify weaknesses early and strengthens an organization's overall security posture.

Whereas, the National Vulnerability Database or NVD is a publicly accessible resource managed by National Institute of Standards and Technology (NIST), which catalogs known cybersecurity vulnerabilities, and they are assigned CVEs. It offers detailed information on security flaws, including severity assessments (using CVSS), impacted systems, and recommended mitigations, aiding organizations in vulnerability management and risk assessment (Emmitt J., 2020).

Step 6 – Identifying Vulnerabilities (Kali Linux):

After identifying open ports and the services running on them, the next step involves analysing the vulnerabilities associated with these open ports. This is essential because protocols like Simple Network Management Protocol (SNMP) and Server Message Block (SMB) can present significant security risks if they are vulnerable.

SNMP is integrated into almost every network device, including routers, switches, printers, and servers. It is widely used by network management tools like HP OpenView and LANDesk for remote monitoring and management of network hosts. While SNMP provides valuable functionality, it also has well-documented security vulnerabilities, especially in older versions like SNMP v1 and v2c, which lack proper encryption and authentication mechanisms.

If an attacker compromises SNMP, they can gain access to sensitive network data, including ARP (Address Resolution Protocol) tables, usernames, and active TCP connections, all of which could be leveraged for malicious purposes. For example, attackers could gather detailed network topology information or exploit weak or default credentials to gain unauthorized access. In some cases, attackers might even modify device configurations, potentially causing network outages or enabling further system compromises.

When SNMP appears in a port scan, it signals a potential attack surface. Cybercriminals often use brute-force tools to guess community strings (the passwords used by SNMP) or take advantage of known protocol vulnerabilities. Once they gain access, they can move across the network, escalate privileges, or launch attacks like denial-of-service.

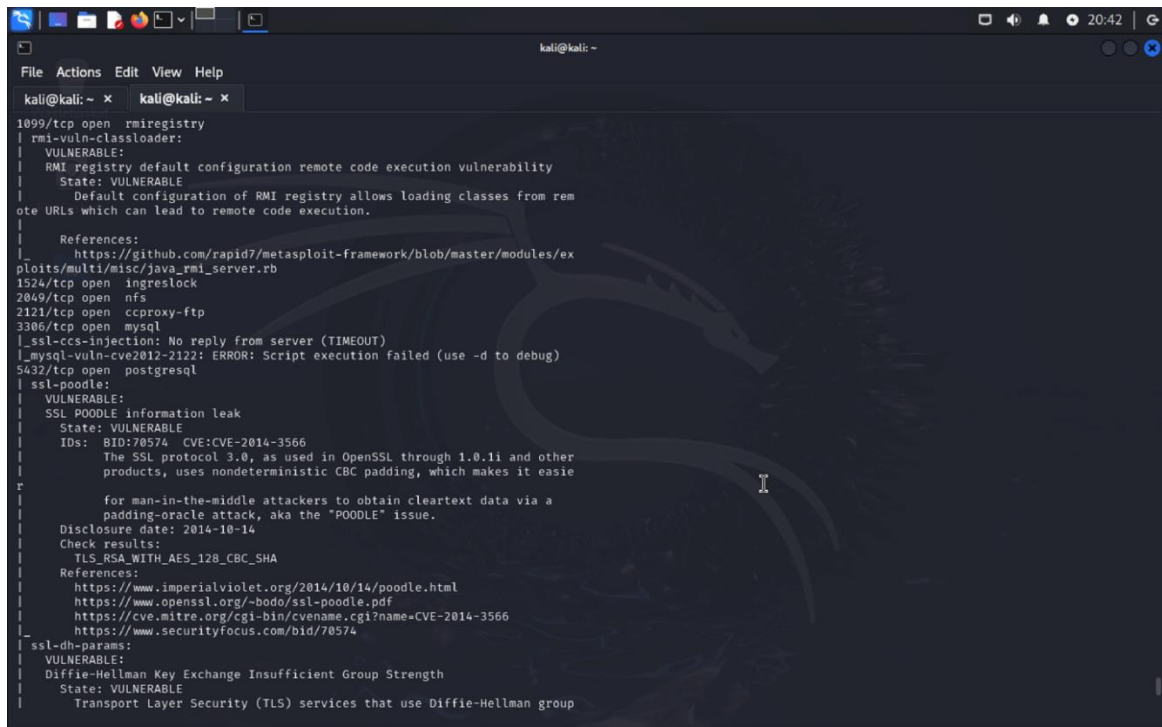
To minimize these risks, it is crucial to disable SNMP if it is not needed, use more secure versions such as SNMP v3 (which includes encryption and authentication), and ensure that community strings are strong and unique. Regularly updating and patching network devices and services can also help reduce exposure to potential exploits.

Command:

`nmap -script vuln <target>`

For example:

`nmap -script vuln 192.168.64.2`



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
1099/tcp open  rmiregistry  
| rmi-vuln-classloader:  
| VULNERABLE:  
| RMI registry default configuration remote code execution vulnerability  
| State: VULNERABLE  
| Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.  
|  
| References:  
| https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb  
1524/tcp open  ingreslock  
2049/tcp open  nfs  
2121/tcp open  ccproxy-ftp  
3306/tcp open  mysql  
|_mysql-cve-injection: No reply from server (TIMEOUT)  
|_mysql-vuln-cve2012-2122: ERROR: Script execution failed (use -d to debug)  
5432/tcp open  postgresql  
| ssl-poodle:  
| VULNERABLE:  
| SSL POODLE information leak  
| State: VULNERABLE  
| IDs: BID:70574 CVE:CVE-2014-3566  
| The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other products, uses nondeterministic CBC padding, which makes it easier for man-in-the-middle attackers to obtain cleartext data via a padding-oracle attack, aka the "POODLE" issue.  
| Disclosure date: 2014-10-14  
| Check results:  
| TLS_RSA_WITH_AES_128_CBC_SHA  
| References:  
| https://www.imperialviolet.org/2014/10/14/poodle.html  
| https://www.openssl.org/~bodo/ssl-poodle.pdf  
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566  
| https://www.securityfocus.com/bid/70574  
|_ssl-dh-params:  
| VULNERABLE:  
| Diffie-Hellman Key Exchange Insufficient Group Strength  
| State: VULNERABLE  
| Transport Layer Security (TLS) services that use Diffie-Hellman group
```

Figure 13. Demonstration and the output of all the vulnerabilities that are present by using “Nmap vuln” script.

```

kali@kali: ~
File Actions Edit View Help
kali@kali: ~ x kali@kali: ~ x
length master key in certain OpenSSL-to-OpenSSL communications, and
consequently hijack sessions or obtain sensitive information, via
a crafted TLS handshake, aka the "CCS Injection" vulnerability.
References:
http://www.cvedetails.com/cve/2014-0224
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
http://www.openssl.org/news/secadv_20140605.txt
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See htt
p://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open ajp13
8180/tcp open unknown
| http-slowloris-check:
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDs: CVE:CVE-2007-6750
Slowloris tries to keep many connections to the target web server ope
n and hold
them open as long as possible. It accomplishes this by opening conne
ctions to
the target web server and sending a partial request. By doing so, it
starves
the http server's resources causing Denial Of Service.
Disclosure date: 2009-09-17
References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
http://hackers.org/slowloris/
MAC Address: BE:48:D7:AA:75:9E (Unknown)
Host script results:
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false
|_smb-vuln-regsdc-dos: ERROR: Script execution failed (use -d to debug)
Nmap done: 1 IP address (1 host up) scanned in 324.83 seconds

```

Figure 14. Demonstration of all the vulnerabilities by using and implementing “Vuln Scanner”.

```

kali@kali: ~
File Actions Edit View Help
kali@kali: ~ x kali@kali: ~ x
ssl-dh-params:
VULNERABLE:
Diffie-Hellman Key Exchange Insufficient Group Strength
State: VULNERABLE
Transport Layer Security (TLS) services that use Diffie-Hellman group
of insufficient strength, especially those using one of a few common
shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
WEAK DH GROUP 1
Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 1024
Generator Length: 8
Public Key Length: 1024
References:
https://weakdh.org
ssl-ccs-injection:
VULNERABLE:
SSL/TLS MITM vulnerability (CCS Injection)
State: VULNERABLE
Risk factor: High
OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
does not properly restrict processing of ChangeCipherSpec messages,
which allows man-in-the-middle attackers to trigger use of a zero
length master key in certain OpenSSL-to-OpenSSL communications, and
consequently hijack sessions or obtain sensitive information, via
a crafted TLS handshake, aka the "CCS Injection" vulnerability.
References:
http://www.cvedetails.com/cve/2014-0224
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
http://www.openssl.org/news/secadv_20140605.txt
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See htt
p://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open ajp13

```

Figure 15. Demonstration of more vulnerabilities discovered and scanned (16) (17).

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
NSE Timing: About 99.81% done; ETC: 20:23 (0:00:00 remaining)  
Nmap scan report for 192.168.64.2  
Host is up (0.00082s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
| ftp-vsftpd-backdoor:  
| VULNERABLE:  
| vsFTPD version 2.3.4 backdoor  
| State: VULNERABLE (Exploitable)  
| IDs: BID:48539 CVE:CVE-2011-2523  
| vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.  
| Disclosure date: 2011-07-03  
| Exploit results:  
| Shell command: id  
| Results: uid=0(root) gid=0(root)  
| References:  
| https://www.securityfocus.com/bid/48539  
| https://github.com/rapid7/metasploit-framework/blob/master/modules/ex  
| ploits/unix/ftp/vsftpd_234_backdoor.rb  
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523  
| http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-  
| backdoored.html  
|_  
22/tcp    open  ssh  
23/tcp    open  telnet  
25/tcp    open  smtp  
| smtp-vuln-cve2010-4344:  
|_ The SMTP server is not Exim: NOT VULNERABLE  
|_ sslv2-drown: ERROR: Script execution failed (use -d to debug)  
| ssl-poodle:  
| VULNERABLE:  
| SSL POODLE information leak  
| State: VULNERABLE  
| IDs: BID:70574 CVE:CVE-2014-3566  
| The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other  
| products, uses nondeterministic CBC padding, which makes it easie  
|_ for man-in-the-middle attackers to obtain cleartext data via a  
| padding-oracle attack, aka the "POODLE" issue.  
| Disclosure date: 2014-10-14  
| Check results:
```

Figure 16

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
VULNERABLE:  
SSL POODLE information leak  
State: VULNERABLE  
IDs: BID:70574 CVE:CVE-2014-3566  
The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other  
products, uses nondeterministic CBC padding, which makes it easie  
_ for man-in-the-middle attackers to obtain cleartext data via a  
padding-oracle attack, aka the "POODLE" issue.  
Disclosure date: 2014-10-14  
Check results:  
TLS_RSA_WITH_AES_128_CBC_SHA  
References:  
https://www.imperialviolet.org/2014/10/14/poodle.html  
https://www.openssl.org/~bodo/ssl-poodle.pdf  
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566  
https://www.securityfocus.com/bid/70574  
ssl-dh-params:  
VULNERABLE:  
Anonymous Diffie-Hellman Key Exchange MitM Vulnerability  
State: VULNERABLE  
Transport Layer Security (TLS) services that use anonymous  
Diffie-Hellman key exchange only provide protection against passive  
eavesdropping, and are vulnerable to active man-in-the-middle attacks  
which could completely compromise the confidentiality and integrity  
of any data exchanged over the resulting session.  
Check results:  
ANONYMOUS DH GROUP 1  
Cipher Suite: TLS_DH_anon_EXPORT_WITH_RC4_40_MD5  
Modulus Type: Safe prime  
Modulus Source: Unknown/Custom-generated  
Modulus Length: 512  
Generator Length: 8  
Public Key Length: 512  
References:  
https://www.ietf.org/rfc/rfc2246.txt  
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM  
(Logjam)  
State: VULNERABLE  
IDs: BID:74733 CVE:CVE-2015-4000
```

Figure 17


```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM  
(Logjam)  
State: VULNERABLE  
IDs: BID:74733 CVE:CVE-2015-4000  
The Transport Layer Security (TLS) protocol contains a flaw that is  
triggered when handling Diffie-Hellman key exchanges defined with  
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker  
to downgrade the security of a TLS session to 512-bit export-grade  
cryptography, which is significantly weaker, allowing the attacker  
to more easily break the encryption and monitor or tamper with  
the encrypted stream.  
Disclosure date: 2015-5-19  
Check results:  
EXPORT-GRADE DH GROUP 1  
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA  
Modulus Type: Safe prime  
Modulus Source: Unknown/Custom-generated  
Modulus Length: 512  
Generator Length: 8  
Public Key Length: 512  
References:  
https://weakdh.org  
https://www.securityfocus.com/bid/74733  
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000  
Diffie-Hellman Key Exchange Insufficient Group Strength  
State: VULNERABLE  
Transport Layer Security (TLS) services that use Diffie-Hellman group  
of insufficient strength, especially those using one of a few common  
shared groups, may be susceptible to passive eavesdropping attacks.  
Check results:  
WEAK DH GROUP 1  
Cipher Suite: TLS_DHE_RSA_WITH_DES_CBC_SHA  
Modulus Type: Safe prime  
Modulus Source: postfix builtin  
Modulus Length: 1024  
Generator Length: 8  
Public Key Length: 1024
```

Figure 18. The end of vulnerabilities scanning process.

Vulnerable 1:

SSL Poodle information leak – (CVE-2014-3566):

SSL POODLE (Padding Oracle on Downgraded Legacy Encryption) is a critical flaw in the SSL 3.0 protocol that enables attackers to exploit weaknesses in Cipher Block Chaining (CBC) mode encryption. By leveraging this flaw, an attacker can carry out a man-in-the-middle (MITM) attack to decrypt sensitive data.

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
VULNERABLE:  
SSL POODLE information leak  
State: VULNERABLE  
IDs: BID:70574 CVE:CVE-2014-3566  
The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other  
products, uses nondeterministic CBC padding, which makes it easie  
for man-in-the-middle attackers to obtain cleartext data via a  
padding-oracle attack, aka the "POODLE" issue.  
Disclosure date: 2014-10-14  
Check results:  
TLS_RSA_WITH_AES_128_CBC_SHA  
References:  
https://www.imperialviolet.org/2014/10/14/poodle.html  
https://www.openssl.org/~bodo/ssl-poodle.pdf  
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566  
https://www.securityfocus.com/bid/70574
```

Figure 19. Demonstration of “SSL Poodle information leak” vulnerability scan output.

Vulnerable 2:

Slowloris DOS Attack – (CVE-2007-6750):

Slowloris is a denial-of-service (DoS) attack designed to exhaust a web server's resources by keeping multiple connections open for an extended period. Instead of overwhelming the server with a flood of traffic, Slowloris operates stealthily using minimal bandwidth, making it challenging to detect and mitigate.

```
http-slowloris-check:
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDs: CVE-2007-6750
Slowloris tries to keep many connections to the target web server open and hold them open as long as possible. It accomplishes this by opening connections to the target web server and sending a partial request. By doing so, it starves the http server's resources causing Denial Of Service.
Disclosure date: 2009-09-17
References:
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
http://hackers.org/slowloris/
```

Figure 20. Demonstration of “Slowloris DOS Attack” vulnerability scan output.

Vulnerable 3:

vsFTPD version 2.3.4 backdoor - (CVE-2011-2523):

CVE-2011-2523 is a backdoor vulnerability discovered in vsFTPD (Very Secure FTP Daemon) version 2.3.4, allowing remote attackers to gain unauthorized root shell access. This issue arose because a malicious version of vsFTPD's source code was intentionally compromised, making it a severe security risk. This is therefore known as one of the highest and critical vulnerabilities that was discovered and identified during the exploitation.

```
ftp-vsftpd-backdoor:
VULNERABLE:
vsFTPD version 2.3.4 backdoor
State: VULNERABLE (Exploitable)
IDs: BID:48539 CVE:CVE-2011-2523
vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
Disclosure date: 2011-07-03
Exploit results:
Shell command: id
Results: uid=0(root) gid=0(root)
References:
https://www.securityfocus.com/bid/48539
https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-
```

Figure 21. Demonstration of “vsFTPD version 2.3.4 backdoor” vulnerability scan output (also considered among one of the highest and sever security risk and vulnerability).

Vulnerable 4:

SSL/TLS MITM Vulnerability (CCS Injection):

The CCS Injection vulnerability (CVE-2014-0224) is a man-in-the-middle (MITM) attack that exploits a flaw in how Open SSL handles the Change Cipher Spec (CCS) message during the SSL/TLS handshake. By injecting a malicious CCS message at the wrong stage, an attacker can force the client and server to use weakened encryption keys, making it possible to decrypt or manipulate sensitive data.

```
ssl-ccs-injection:
VULNERABLE:
SSL/TLS MITM vulnerability (CCS Injection)
State: VULNERABLE
Risk factor: High
OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
does not properly restrict processing of ChangeCipherSpec messages,
which allows man-in-the-middle attackers to trigger use of a zero
length master key in certain OpenSSL-to-OpenSSL communications, and
consequently hijack sessions or obtain sensitive information, via
a crafted TLS handshake, aka the "CCS Injection" vulnerability.

References:
http://www.cvedetails.com/cve/2014-0224
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
http://www.openssl.org/news/secadv_20140605.txt
```

Figure 22. Demonstration of “SSL/TLS MITM” vulnerability scan output.

Vulnerable 5:

Transport Layer Security (TLS) Protocol DHE_Export Ciphers Downgrade MitM (Logjam) – (CVE-2015-4000):

The Logjam vulnerability (CVE-2015-4000) is a man-in-the-middle (MITM) attack that takes advantage of weak Diffie-Hellman (DH) key exchange when export-grade cryptography is supported. By forcing the use of insecure 512-bit DHE_EXPORT ciphers, an attacker can significantly weaken encryption, making it possible to decrypt or manipulate secure communications.

```
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM
(Logjam)
State: VULNERABLE
IDs: BID:74733 CVE:CVE-2015-4000
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8
Public Key Length: 512
References:
https://weakdh.org
https://www.securityfocus.com/bid/74733
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
```

Figure 23. Demonstration of “Transport Layer Security (TLS) Protocol DHE_Export Ciphers Downgrade MitM (Logjam)” vulnerability scan output.

Validation of Vulnerabilities Using Public Resources

To ensure accuracy and relevance, identified vulnerabilities were carefully validated using industry-standard resources and verification methods.

1. Cross-Referencing with Public Databases:

Each discovered vulnerability was verified using authoritative security databases:

- **Common Vulnerabilities and Exposures (CVE):** Identified vulnerabilities were checked against the CVE database to confirm their existence, severity, and known exploits. CVE identifiers (e.g., CVE-2024-XXXX) helped maintain consistency with industry standards.

- **National Vulnerability Database (NVD):** The NVD provided additional details, including CVSS scores, affected software versions, and recommended mitigation strategies, helping to assess the impact on Acme Corporation's systems.

2. Manual Verification and Proof-of-Concept (PoC) Testing:

To confirm the exploitability of each vulnerability:

- Proof-of-Concept (PoC) exploits from reputable sources (such as ExploitDB or vendor advisories) were tested in a controlled environment.

- If no PoC was available, customized testing methods were applied to verify security weaknesses.

- False positives were eliminated by analysing system configurations, logs, and behaviour to confirm the findings.

3. Vendor and Community Advisories:

- Security bulletins from software vendors (e.g., Microsoft, Cisco, Apache) were reviewed for patch availability and known mitigations.

- Cybersecurity communities and research forums (e.g., MITRE, OWASP, security mailing lists) were consulted for insights into emerging threats and best practices for remediation.

In overall summary and conclusion, by combining these validation techniques, Acme Corporation received a refined list of confirmed vulnerabilities, ensuring that remediation efforts focused only on genuine security threats.

3.4 Exploitation of an Identified Vulnerability

Step 7 – Exploitation of One Identified Vulnerability:

Exploiting a crucial and identified vulnerability means taking advantage of a known security flaw in a system, application, or service that has been discovered and publicly reported. When a vulnerability is labelled as “crucial,” it indicates that the flaw is highly impactful and could potentially cause significant harm if exploited, such as:

- Full system compromise (giving unauthorized access, like root or admin privileges).
- Exposure of sensitive data (e.g., personal or confidential information).
- Service disruption (e.g., crashing the system or making it unavailable).
- Privilege escalation (where an attacker gains higher-level access than intended).

Therefore, exploitation refers to the act of actively using the identified vulnerability to gain unauthorized access or perform harmful actions on the target system. This could involve:

1. Taking control: Using the flaw to run malicious code, access unauthorized data, or manipulate system functions.

2. Bypassing security measures: The attacker might bypass defences like authentication or encryption, allowing them to read, alter, or delete data.

3. Expanding the attack: The attacker could use the exploit to access other systems or networks or escalate the attack to more critical parts of the environment.

In essence, exploiting a crucial and identified vulnerability means using a publicly known security weakness to harm the system, steal information, or gain unauthorized control.

Exploitation plays a key role in penetration testing, but it’s crucial that it’s carried out responsibly and ethically. First and foremost, we must ensure that we have the necessary permission to perform the test. It should only be conducted by trained professionals who have a thorough understanding of the process to avoid causing any harm to the system.

In this case, as outlined below, we will exploit the database management system to gain a deeper understanding of the exploitation process and provide actionable recommendations.

To start or begin with, we will use the Metasploit Framework, executing the command on the target machine: “msfconsole”.



Figure 24. The demonstration and the outcome of the configured command “msfconsole”.

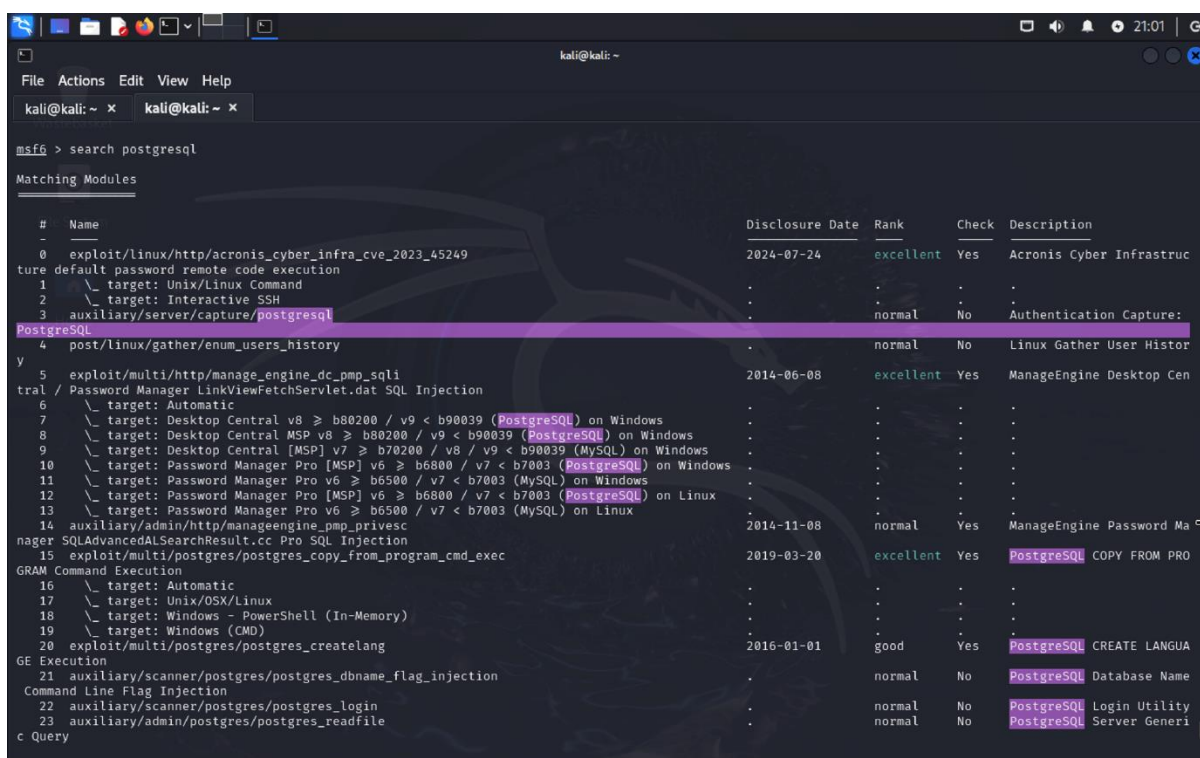


Figure 25. Demonstration and the outcome of “search postgresql” under the “msf6” command (26).

4. Findings, Risk Analysis and Recommendation

Coming to this last stage, some of the main vulnerabilities with their severity level of effectiveness discovered during the penetration test are listed in the following:

Vulnerable 1:

SSL Poodle information leak – (CVE-2014-3566):

1) Vulnerability Overview:

- **CVE ID:** CVE-2014-3566
 - **Affected Systems:** Any system supporting SSL 3.0, including web browsers, servers, and applications using SSL encryption.
 - **Severity:** High
 - **Discovered by:** Google Security Team (2014)
-

2) Attack Mechanism:

1. The attacker forces a protocol downgrade from TLS (a secure protocol) to SSL 3.0, which is outdated and vulnerable.
 2. Using a padding oracle attack, the attacker manipulates encrypted data blocks and observes system responses to gradually decrypt sensitive information.
 3. This attack is particularly dangerous in man-in-the-middle (MITM) scenarios, where an attacker has network access and can intercept communications.
-

3) Potential Impact:

- Enables theft of authentication cookies, session tokens, and confidential data.
 - Can be executed in environments where attackers can control network traffic, such as public Wi-Fi networks.
-

4) Mitigation Strategies (Solution):

- Disable SSL 3.0 on servers, applications, and browsers.
- Enforce TLS 1.2 or higher to prevent fallback to insecure protocols.
- Implement TLS_FALLBACK_SCSV to stop attackers from forcing protocol downgrades.
- Ensure software and systems are updated to eliminate SSL 3.0 support.

Vulnerable 2:

Slowloris DOS Attack – (CVE-2007-6750):

1) Vulnerability Overview:

- **CVE ID:** CVE-2007-6750
 - **Attack Type:** Denial-of-Service (DoS)
 - **Affected Systems:** Web servers that rely on thread-based request handling (e.g., Apache, older IIS versions, and other similar web servers).
 - **Severity:** High
 - **Discovered by:** RSnake (2009)
-

2) How the Attack Works:

1. The attacker initiates multiple connections to the target web server.
 2. Instead of completing the HTTP requests, it sends partial headers at a slow pace, keeping each connection alive.
 3. Since the server waits for the incomplete requests to finish, it holds resources for too long, preventing new legitimate connections.
 4. Over time, all available server connections are occupied, resulting in denial of service for real users.
-

3) Potential Impact:

- Causes the web server to become unresponsive, disrupting normal operations.
 - Since it requires very little bandwidth, a single attacker can execute the attack without needing a large botnet.
 - It is hard to detect because it doesn't generate the high traffic spikes typically associated with DoS or DDoS attacks.
-

4) Mitigation Strategies (Recommendation and Solution):

- Deploy a reverse proxy or load balancer (e.g., Nginx, Cloudflare, AWS WAF) to filter out suspicious traffic.
- Set request timeouts to limit how long the server waits for incomplete requests.

- Restrict the number of concurrent connections for each IP addresses.
- Use Web Application Firewalls (WAF) or intrusion detection systems (IDS) to detect and block slow connection attacks.
- Enable `mod_reqtimeout` in Apache to automatically close slow connections.

Vulnerable 3:

vsFTPD version 2.3.4 backdoor - (CVE-2011-2523):

1) Vulnerability Overview:

- **CVE ID:** CVE-2011-2523
 - **Type of Vulnerability:** Backdoor / Remote Code Execution (RCE)
 - **Affected Software:** vsFTPD 2.3.4 (compromised version)
 - **Severity:** Critical
 - **Discovered by:** Chris Evans (2011)
 - **Status:** The compromised version was quickly removed and replaced with a clean release.
-

2) How the Exploit Works:

1. An attacker connects to the vsFTPD server and logs in with a username ending in :) (smiley face).
 2. If the server is running the backdoored version, this login triggers a hidden shell.
 3. The backdoor opens a root shell on TCP port 6200, giving the attacker full control of the system.
 4. The attacker can then execute arbitrary commands and completely compromise the server.
-

3) Impact of the Vulnerability:

- Full system compromise, granting the attacker root-level access.
 - Potential for data theft, modification, or further attacks on connected systems.
 - Possibility of lateral movement, enabling the attacker to infiltrate other parts of the network.
-

4) Mitigation & Remediation (Recommendation and Solution):

- Check your vsFTPD version: If using 2.3.4, upgrade immediately to a secure version.
- Remove any unverified vsFTPD installations and reinstall from official sources.
- Monitor or block TCP port 6200 to detect and prevent unauthorized access.
- Use a firewall to restrict FTP service access and log suspicious activity.
- Consider switching to a more secure alternative like SFTP (via OpenSSH) instead of vsFTPD.
- Regularly audit system files and logs to identify any signs of tampering or unauthorized activity.

Vulnerable 4:

SSL/TLS MITM Vulnerability (CCS Injection):

1) Vulnerability Overview:

- **CVE ID:** CVE-2014-0224
 - **Type:** Man-in-the-Middle (MITM) Attack
 - **Affected Systems:** Any server or client running OpenSSL versions 1.0.1 through 1.0.1g
 - **Severity:** High
 - **Discovered by:** Masashi Kikuchi (2014)
 - **Impact:** Allows attackers to weaken SSL/TLS encryption and intercept private communications.
-

2) How the Exploit Works:

1. An attacker positions themselves between a client and a server (MITM scenario).
 2. During the SSL/TLS handshake, they send a forged ChangeCipherSpec (CCS) message too early.
 3. This forces the handshake to complete with predictable encryption keys instead of secure ones.
 4. The attacker can then decrypt, modify, or impersonate communications without detection.
-

3) Impact of the Vulnerability:

- Sensitive data exposure, such as passwords, financial transactions, and confidential messages.

- Session hijacking, where attackers take control of user sessions.
 - Compromised SSL/TLS encryption, undermining HTTPS security.
-

4) Mitigation & Security Measures (Recommendation and Solution):

- Update OpenSSL to version 1.0.1h or later, as the issue has been patched.
- Ensure all software and servers using OpenSSL are upgraded to secure versions.
- Use strong TLS configurations, enforcing TLS 1.2 or higher whenever possible.
- Implement HTTP Strict Transport Security (HSTS) to prevent MITM attacks by enforcing encrypted connections.
- Monitor for unusual SSL/TLS handshake behaviour to detect potential attacks.

Vulnerable 5:

Transport Layer Security (TLS) Protocol DHE_Export Ciphers Downgrade MitM (Logjam) – (CVE-2015-4000):

1) Vulnerability Overview:

- **CVE ID:** CVE-2015-4000
 - **Type:** Man-in-the-Middle (MITM) / Cryptographic Weakness
 - **Affected Systems:** Any server or client using Diffie-Hellman key exchange with weak 512-bit (DHE_EXPORT) ciphers
 - **Severity:** High
 - **Discovered by:** Security researchers from various institutions (2015)
 - **Impact:** Allows attackers to intercept and decrypt secure connections over HTTPS, SSH, VPNs, and other TLS-based services.
-

2) How the Attack Works:

1. A server that supports export-grade Diffie-Hellman (DHE_EXPORT) ciphers is targeted.
2. The attacker intercepts the TLS handshake and tricks both the client and server into using a weak 512-bit DH key instead of a stronger one.

3. Since common 512-bit DH keys can be precomputed, the attacker can quickly decrypt communications without needing real-time computation.
 4. Once the encryption is weakened, the attacker gains the ability to read, modify, or inject data into the connection.
-

3) Impact of the Vulnerability:

- Interception of encrypted traffic, allowing sensitive data such as credentials, financial details, and private messages to be exposed.
 - Session hijacking, enabling attackers to impersonate users or alter communication content.
 - Compromised HTTPS security, affecting web services that still support outdated DH ciphers.
-

4) Mitigation & Security Measures (Recommendation and Solution):

- Disable support for DHE_EXPORT ciphers on all TLS-enabled servers and applications.
- Use Diffie-Hellman key sizes of at least 2048 bits to prevent easy precomputation attacks.
- Ensure all software and TLS implementations (e.g., OpenSSL, web servers, VPNs) are updated.
- Enable forward secrecy with Elliptic Curve Diffie-Hellman (ECDH) instead of standard DH.
- Test servers for weak DH parameters using tools like SSL Labs' SSL Test.

5. Conclusion

The penetration test and the report as a whole conducted for Acme Corporation organisation identified several vulnerabilities that could be exploited by attackers, potentially compromising customer data, business operations, and overall system security. By systematically following an ethical hacking methodology, we uncovered weaknesses such as authentication flaws, improper input validation, outdated software, and misconfigurations within the web application and internal network. These vulnerabilities, if left unaddressed, could lead to data breaches, financial losses, or reputational damage.

This report underscores the necessity of adopting a proactive security approach to mitigate cyber threats. Regular penetration testing is essential for identifying and addressing security gaps before they can be exploited by malicious actors. Additionally, Acme Corporation should implement continuous security monitoring, enforce strong access control policies, and adopt a comprehensive patch management strategy to keep software and systems up to date.

Beyond technical measures, fostering a security conscious culture within the organization is crucial. Employee training on cybersecurity best practices, regular security awareness programs, and adherence to industry standards can significantly reduce the risk of human errors leading to security incidents.

By taking a holistic approach to cybersecurity and incorporating technical safeguards, policy enforcement, and ongoing security assessments, Acme Corporation can enhance its overall security posture, ensuring the protection of customer data, business operations, and corporate infrastructure against evolving cyber threats.

6. References

- [1] What is UTM? (n.d.) *UTM Documentation*. Online. Available at: <https://docs.getutm.app/> (Accessed: 31 March 2025).
- [2] TheKnowledgeAcademy (n.d.) *What is Kali linux? definition, history, & features, The Knowledge Academy - Online certification training courses provider*. Online. Available at: <https://www.theknowledgeacademy.com/blog/what-is-kali-linux/> (Accessed: 30 March 2025).
- [3] Metasploitable 2 (n.d.) *Metasploitable 2 | Metasploit Documentation*. Online. Available at: <https://docs.rapid7.com/metasploit/metasploitable-2/> (Accessed: 31 March 2025).
- [4] Computer Networks (n.d.) *Network Address Translation Definition: How Nat Works: CompTIA*. Online. Available at: <https://www.comptia.org/content/guides/what-is-network-address-translation> (Accessed: 31 March 2025).
- [5] McCarvill, A. (2024) *What is penetration testing? process, types, and Tools, Bright Security*. Online. Available at: <https://brightsec.com/blog/penetration-testing/> (Accessed: 31 March 2025).
- [6] Teendifferent (2022) *Information gathering in cyber security: Definition, types, tools & techniques., Medium*. Online. Available at: <https://medium.com/@teendifferent/information-gathering-in-cyber-security-definition-types-tools-techniques-ae59cb394bf6> (Accessed: 31 March 2025).
- [7] Kirvan, P., Nolle, T. and Intel A. (2024) *What is network scanning? how to, types and best practices, Search Networking*. Online. Available at: <https://www.techtarget.com/searchnetworking/definition/network-scanning> (Accessed: 31 March 2025).
- [8] Shivanandhan, M. (2020) *What is nmap and how to use it – a tutorial for the greatest scanning tool of all time, freeCodeCamp.org*. Online. Available at: <https://www.freecodecamp.org/news/what-is-nmap-and-how-to-use-it-a-tutorial-for-the-greatest-scanning-tool-of-all-time/> (Accessed: 31 March 2025).
- [9] Black duck (n.d.) *What is a vulnerability assessment and how does it work?: What Is a Vulnerability Assessment and How Does It Work? | Black Duck*. Online. Available at: <https://www.blackduck.com/glossary/what-is-vulnerability-assessment.html> (Accessed: 31 March 2025).
- [10] Awati, R. (2025) *What is the nessus vulnerability scanning platform?: Definition from TechTarget, Search Networking*. Online. Available at: <https://www.techtarget.com/searchnetworking/definition/Nessus> (Accessed: 31 March 2025).
- [11] GeeksforGeeks (2024) *OpenVAS : Security assessment, GeeksforGeeks*. Online. Available at: <https://www.geeksforgeeks.org/security-assessment-openvas/> (Accessed: 31 March 2025).
- [12] Nikto (n.d.) *Nikto - an overview | ScienceDirect Topics*. Online. Available at: <https://www.sciencedirect.com/topics/computer-science/nikto> (Accessed: 31 March 2025).
- [13] Courtney Goodman (2025) *What are common vulnerabilities and exposures (CVE)?, Balbix*. Online. Available at: <https://www.balbix.com/insights/what-is-a-cve/> (Accessed: 31 March 2025).
- [14] Emmitt, J. (2024) *The National Vulnerability Database (NVD) explained, Kaseya*. Online. Available at: <https://www.kaseya.com/blog/national-vulnerability-database-nvd/> (Accessed: 31 March 2025).